AP

APEX

by Ing. Antony Pérez

Manual Técnico

Arquitectura, base de datos, reglas de negocio de caja y descuadres, concurrencia, seguridad, pruebas y mantenimiento del código.

Dirigido a: desarrolladores y soporte técnico

APEX — Sistema Integral de Gestión

Versión 1.0 · Octubre 2026

© APEX by Ing. Antony Pérez

Contenido

1. Visión general
2. Estructura de archivos
3. Ciclo de una petición
4. Configuración y arranque
5. Base de datos
6. Ventas y formas de pago
7. Caja: sesiones y cuadre
8. Descuadres y ajustes
9. Concurrencia
10. Seguridad
11. Reportes Excel y PDF
12. Interfaz (frontend)
13. Pruebas automáticas
14. Mantenimiento y extensión

© APEX by Ing. Antony Pérez

1. Visión general

APEX es una aplicación web monolítica en **PHP 8 procedimental**, sin framework, con renderizado del lado del servidor y base de datos **MariaDB/MySQL** vía PDO. Cada módulo es un archivo `.php` que procesa sus formularios (POST) y genera su HTML. La interfaz usa Bootstrap 5, Font Awesome y SweetAlert2 desde CDN.

CAPA	TECNOLOGÍA
Servidor	Apache 2.4 + PHP 8.2 (XAMPP), `.htaccess` con cabeceras de seguridad
Datos	MariaDB 10.4 / MySQL 8, InnoDB, utf8mb4, PDO con sentencias preparadas reales
Interfaz	Bootstrap 5.3, Font Awesome 6.5, SweetAlert2 11, JavaScript sin dependencias
Exportación	Excel .xlsx generado en PHP puro (`includes/xlsx.php`); PDF del cierre con html2pdf.js en el navegador
Pruebas	Bash + curl (`tests/e2e.sh`) y Python + Playwright con Edge (`tests/ui_test.py`)

© APEX by Ing. Antony Pérez

2. Estructura de archivos

ARCHIVO	FUNCIÓN
`config/config.php`	Lee `config.local.php` o las variables `APEX_*` y define las constantes (BD, marca, seguridad, depuración); zona horaria, manejo de errores, `app_session_start()`, `app_pdo()`, `app_copyright()`.
`config/config.local.example.php`	Plantilla de la configuración de cada instalación (`config.local.php`, excluido del repositorio).
`config/conexion.php`	Incluido por todas las páginas internas: sesión, exigencia de login, expiración por inactividad, CSRF, helpers (`h`, `flash_*`, `delete_button`, colores, formas de pago), conexión y validación del usuario vigente.
`includes/header.php`, `footer.php`	Layout: menú según rol, estilos, pie con copyright, scripts (formato de dinero, confirmaciones, mensajes).
`includes/caja_funciones.php`	Lógica de caja: `caja_abierta`, `caja_abierta_bloqueada`, `caja_abrir`, `caja_get`, `caja_resumen`, `caja_descuadres`, `caja_descuadres_pendientes`, `caja_ajustes`.
`includes/xlsx.php`	Generador de Excel (clases `Xlsx` y `XlsxSheet`): encabezados, indicadores, tablas con totales y filtros.
`index.php` / `logout.php`	Inicio de sesión con bloqueo por intentos / cierre de sesión.
`cambiar_clave.php`	Cambio de contraseña propio y obligatorio (`usuarios.debe_cambiar_clave`).
`dashboard.php`	Indicadores, estado de caja, descuadres pendientes, ventas recientes, stock bajo.
`ventas.php`, `ticket.php`	Punto de venta (carrito en sesión, pagos, obsequios) y ticket térmico.
`abonos.php`	Cartera: abonos y endpoint AJAX de historial (`?ajax_abonos=ID`).
`caja.php`, `caja_reporte.php`	Apertura, movimientos, arqueo/cierre, descuadres y ajustes; reporte imprimible/PDF.
`clientes.php`, `proveedores.php`, `productos.php`, `averiados.php`	CRUD de clientes, proveedores (admin), inventario y categorías (admin), bajas de inventario (admin).
`reportes.php`, `exportar*.php`	Reportes: ventas, inventario, cartera y descuadres en Excel.
`usuarios.php`, `backup.php`, `configuracion.php`	Administración.
`setup.php`	Instalador/migrador idempotente (web solo para admin, o CLI).

© APEX by Ing. Antony Pérez

`tests/`, `docs/fuente/`	Pruebas y fuentes de los manuales (bloqueadas por `.htaccess`).
`deploy/`, `docker/`, `Dockerfile`, `docker-compose.yml`	Despliegue: VirtualHost de Apache, servidor Nginx, script de base de datos e imagen Docker (Apache + PHP 8.2) con MariaDB.
`.github/`	Integración continua (sintaxis PHP 8.1–8.3 e instalación sobre MariaDB) y política de seguridad.

© APEX by Ing. Antony Pérez

3. Ciclo de una petición

1. `require 'config/conexion.php'` → carga `config.php`, abre la sesión segura, exige login (si no, redirige a `index.php`), controla la inactividad, genera el token CSRF, conecta a la BD y recarga `nombre` y `rol` del usuario desde la base (si fue eliminado, cierra la sesión).
2. Control de permisos del módulo (`$rol !== 'admin'` → «Acceso denegado» o redirección).
3. Procesamiento de POST: `csrf_verify()`, validación, escritura en transacción cuando aplica y **redirección** con `flash_redirect()` (patrón Post/Redirect/Get: recargar la página no repite la operación).
4. Consultas de lectura y `include 'includes/header.php'`.
5. HTML del módulo (toda salida de datos pasa por `h()`) e `include 'includes/footer.php'`.

Las páginas independientes (`ticket.php`, `caja_reporte.php`) incluyen `conexion.php` pero generan su propio HTML para impresión. Las exportaciones envían el archivo y terminan.

Funciones auxiliares (conexion.php)

FUNCIÓN	USO
`csrf_field()` / `csrf_verify()`	Campo oculto con el token y verificación (403 si no coincide).
`h($s)`	`htmlspecialchars` con ENT_QUOTES y UTF-8.
`flash_redirect($url,$msg,$tipo)` / `flash_get()`	Mensaje de una sola vez en sesión + redirección.
`delete_button($id,$confirm,$campo)`	Formulario POST con CSRF y confirmación SweetAlert.
`forma_pago_label()`, `FORMAS_PAGO`, `METODOS_CAJA`, `METODOS_CARTERA`	Catálogo de formas de pago.
`COLORES`, `color_hex()`, `color_badge()`, `producto_label()`	Colores de producto y etiquetas «Nombre · Color».

© APEX by Ing. Antony Pérez

4. Configuración y arranque

`config/config.php` no se edita en cada instalación. Primero carga `config/config.local.php` si existe; luego define con `defined() || define()` cada constante que falte, tomando las variables de entorno `APEX_DB_HOST`, `APEX_DB_PORT`, `APEX_DB_USER`, `APEX_DB_PASS`, `APEX_DB_NAME` y `APEX_DEBUG` o los valores por defecto. Constantes: `DB_*`, `APP_NAME`, `APP_AUTHOR`, `APP_VERSION`, `SESION_INACTIVIDAD_MIN`, `PASSWORD_MIN` y `APP_DEBUG`. Además:

- Zona horaria `America/Bogota` en PHP y `SET time_zone='-05:00'` en cada conexión, para que `NOW()` y `CURDATE()` coincidan con PHP.
- Con `APP_DEBUG=false`: `display_errors=0`, errores a `logs/php_errors.log` y un `set_exception_handler` que registra la excepción y muestra una página genérica (HTTP 500).
- `app_session_start()`: cookie `APEXSESSID` con `HttpOnly`, `SameSite=Lax`, `Secure` automático bajo HTTPS y `use_strict_mode`.
- `app_pdo()`: PDO con excepciones, `FETCH_ASSOC` y `EMULATE_PREPARES=false`.

Instalador / migrador

`setup.php` es idempotente: `CREATE TABLE IF NOT EXISTS` y `ALTER TABLE … ADD COLUMN` envueltos en `try` (si la columna ya existe, se ignora). Para añadir un cambio de esquema en una versión nueva se agrega al bloque de migraciones con un comentario de versión. Acceso: CLI siempre; web solo si la base no tiene usuarios (primera instalación) o si el visitante es un administrador con sesión.

© APEX by Ing. Antony Pérez

5. Base de datos

Base `apex_db` — 14 tablas InnoDB utf8mb4. Líneas azules: clave foránea con `ON DELETE CASCADE`; líneas grises punteadas: relación lógica controlada por la aplicación.



Modelo de datos de APEX (campos principales)

Puntos clave

- **id_caja** en `ventas`, `abonos` y `caja_chica` liga cada operación a la sesión de caja en la que ocurrió. Los registros previos a la versión con cajas tienen `id_caja` NULL.
- **pagos_venta** guarda el desglose del pago (una fila por método; los pagos mixtos tienen varias). `ventas.estado` guarda la forma de pago principal.
- **caja_chica** registra todo el dinero real: ventas y abonos por medios de caja, gastos e ingresos manuales y ajustes de descuadres (`ajusta_caja` = caja descuadrada a la que corresponde el ajuste).
- No hay borrado de ventas: los productos, clientes y usuarios con historial no se pueden eliminar desde la aplicación.

© APEX by Ing. Antony Pérez

6. Ventas y formas de pago

CONSTANTE	VALORES	SIGNIFICADO
`METODOS_CAJA`	Efectivo, Transferencia, Tarjeta	Dinero recibido: genera un ingreso en `caja_chica` con su `metodo`.
`METODOS_CARTERA`	Terceros, Credito Interno	Suma a `ventas.saldo_pendiente`; se cobra luego con abonos.
`FORMAS_PAGO`	las anteriores + Mixto	Mixto exige que la suma de pagos coincida con el total (±0,02).

Proceso de cobro (`ventas.php`)

1. Validaciones previas: caja abierta, stock del carrito, forma de pago, cliente existente, entidad para Terceros, cliente registrado y autorizador para Crédito Interno, suma del mixto.
2. Transacción: bloqueo de la caja abierta (`caja_abierta_bloqueada`), inserción de la venta con `id_caja`, filas de `pagos_venta` y `detalles_venta`.
3. Descuento de stock con `UPDATE … SET stock=stock-? WHERE id=? AND stock>=?`; si no afecta filas, se revierte («Stock insuficiente»).
4. Obsequios: precio 0 y registro en `inventario_movimientos`.
5. Ingresos en `caja_chica` por cada pago con método de caja; `commit`.

El carrito vive en `$_SESSION['carrito']` con claves `p{id}` (vendido) y `g{id}` (obsequio).

© APEX by Ing. Antony Pérez

7. Caja: sesiones y cuadre

- Solo puede existir una caja con `estado='Abierta'`. `caja_abrir()` usa `GET_LOCK('apex_abrir_caja')` para evitar dos aperturas simultáneas.
- La caja no tiene cierre automático: ningún cálculo depende de la fecha, todo se agrupa por `id_caja`.
- Ventas y abonos requieren caja abierta; los gastos/ingresos manuales y los ajustes son exclusivos del administrador.
- Apertura y cierre los pueden hacer vendedor y administrador.

`caja_resumen($pdo, $caja)`

Devuelve ventas con sus ítems y pagos, abonos, movimientos manuales (incluye ajustes registrados en esa caja), totales por medio y por origen (ventas/abonos/ingresos/egresos), ventas por forma de pago con desglose por entidad de Terceros, productos consolidados, cartera generada y el efectivo esperado:

efectivo_esperado = monto_inicial + Σ ingresos(Efectivo) − Σ egresos(Efectivo) (en caja_chica, id_caja = caja)

Cierre

En una transacción se bloquea la fila de la caja, se calcula el esperado (incluyendo cualquier operación que estuviera en curso) y se guardan `efectivo_esperado` y `efectivo_contado` como fotografía del arqueo; luego se redirige a `caja_reporte.php?id=N&cerrada=1`, que descarga el PDF automáticamente.

© APEX by Ing. Antony Pérez

8. Descuadres y ajustes

Un descuadre es una caja cerrada con `|efectivo_contado − efectivo_esperado| ≥ 0,01`. No es una tabla aparte: se calcula en `caja_descuadres()`:

- **tipo**: Faltante si contado < esperado; Sobrante en caso contrario. **monto** = valor absoluto de la diferencia.
- **ajustado**: suma de `caja_chica.monto` con `ajusta_caja = id` y tipo Ingreso (faltante) o Egreso (sobrante).
- **pendiente** = monto − ajustado; **estado** Pendiente o Cuadrado (fecha del último ajuste).

Cuadrar (`caja.php` , POST `cuadrar_descuadre`): solo administrador, requiere caja abierta. En una transacción bloquea la caja abierta y la caja descuadrada, recalcula el pendiente, valida `0 < monto ≤ pendiente` e inserta en `caja_chica` un movimiento con `id_caja` = caja abierta, `ajusta_caja` = caja descuadrada y `referencia_origen = 'Ajuste caja #N'`. Se permiten ajustes parciales.

Los descuadres se muestran en el Dashboard, en Caja (pendientes y en el historial de cierres), en `caja_reporte.php` (el propio y los pendientes de otras cajas), en Reportes y en `exportar_descuadres.php`.

© APEX by Ing. Antony Pérez

9. Concurrencia

RIESGO	SOLUCIÓN
Dos aperturas de caja simultáneas	`GET_LOCK` con nombre alrededor de la verificación e inserción.
Venta, abono o movimiento registrado mientras se cierra la caja	`SELECT … FOR UPDATE` sobre la caja abierta dentro de la transacción; el cierre también bloquea la fila, así que se serializan y nada cae en una caja ya cerrada.
Vender el último producto dos veces	`UPDATE … WHERE stock >= cantidad` y verificación de `rowCount()`.
Dos abonos que juntos superan el saldo	Relectura de `saldo_pendiente` con `FOR UPDATE` dentro de la transacción.
Dos ajustes que superan el pendiente	Bloqueo de la caja descuadrada y recálculo del pendiente dentro de la transacción.

© APEX by Ing. Antony Pérez

10. Seguridad

AMENAZA	CONTROL
Inyección SQL	Sentencias preparadas con `EMULATE_PREPARES=false` en todas las consultas con datos del usuario.
XSS	`h()` en toda salida HTML; los mensajes de SweetAlert usan `titleText` / `text` (nunca HTML); `json_encode` para datos en JavaScript.
CSRF	Token por sesión (32 bytes aleatorios) verificado con `hash_equals` en todos los POST.
Contraseñas	`password_hash` (bcrypt); mínimo `PASSWORD_MIN`; nunca se muestran. `debe_cambiar_clave=1` (usuarios iniciales del instalador, o quien conserve `admin123` / `vendedor123`) obliga a pasar por `cambiar_clave.php` antes de cualquier otra página.
Fuerza bruta / enumeración	Tabla `login_intentos`: 5 fallos por IP en 15 min bloquean; mismo mensaje y mismo tiempo de respuesta exista o no el usuario (verificación contra hash ficticio).
Sesión	Cookie HttpOnly/SameSite/Secure, `session_regenerate_id` al ingresar, expiración por inactividad, rol leído de la BD en cada petición.
Control de acceso	Verificación de rol en servidor en cada módulo y acción (no solo ocultar menús).
Exposición de archivos	`.htaccess`: `Options -Indexes`, denegación de `config`, `includes`, `logs`, `tests`, `docs/fuente` y extensiones `.sql .log .sh .md .ini`.
Cabeceras	Content-Security-Policy (solo el propio sitio y los CDN usados; `object-src 'none'`, `frame-ancestors 'self'`, `form-action 'self'`), X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy, sin X-Powered-By.
Fuga de información	Errores solo al log; mensajes genéricos al usuario.
Instalador	`setup.php` bloqueado tras la instalación salvo administrador o CLI.

Limitación conocida
Los scripts en línea requieren `'unsafe-inline'` en la CSP. El escapado de salida es la defensa principal contra XSS; la CSP limita los orígenes externos.

© APEX by Ing. Antony Pérez

11. Reportes Excel y PDF

Excel (`includes/xlsx.php`)

Genera .xlsx (OpenXML en ZIP) sin librerías externas. API principal:

```
$x  = new Xlsx('Título');
$sh = $x->sheet('Hoja');
$x->header($sh, 'Título', ['línea 1', 'línea 2'], $columnas);
$x->kpis($sh, [['Etiqueta', $valor, 'money'], …]);
$x->table($sh, [['Columna', 'money', 16], …], $filas, ['label' => 'TOTAL', 'sum' => [3]], ['red' =>
fn($f) => […]]);
$x->download('archivo.xlsx');
```

Tipos de columna: `text, money, int, pct, date, datetime, center`. Los totales usan `SUBTOTAL()` para respetar los filtros.

PDF del cierre

`caja_reporte.php` es HTML imprimible; el botón «Descargar PDF» usa html2pdf.js (cdnjs) en el navegador con tamaño carta y saltos de página que evitan cortar filas. Sin internet cae a `window.print()`.

© APEX by Ing. Antony Pérez

12. Interfaz (frontend)

- **Campos de dinero:** todo `<input type="number" step="0.01">` se convierte (en `footer.php`) en un campo de texto con separador de miles; el input original queda oculto con el valor limpio que llega al servidor. Excluir con `data-no-format`.
- **Confirmaciones:** cualquier `<form>` o `<a>` con `data-confirm="mensaje"` (y opcional `data-confirm-btn`) muestra SweetAlert antes de enviar.
- **Mensajes:** los `.alert-dismiss` generados por PHP se convierten en toast (éxito) o ventana (error).
- **Diseño adaptable:** menú lateral desplegable bajo 1024 px; probado sin desborde horizontal a 390 px.

© APEX by Ing. Antony Pérez

13. Pruebas automáticas

ARCHIVO	QUÉ CUBRE
`tests/e2e.sh`	Bash + curl contra la instancia local (≈140 pruebas): login y bloqueo, marca y cabeceras, carpetas protegidas, setup, productos, caja (apertura, ventas, cierre, arqueo), todas las formas de pago, abonos (incluida la concurrencia), clientes, proveedores, usuarios, permisos del vendedor, descuadres y ajustes, categorías, exportaciones, validaciones del servidor y ausencia de errores nuevos en el log.
`tests/ui_test.py`	Playwright + Edge (≈47 pruebas): cada página sin errores de JavaScript ni bloqueos CSP, XSS en mensajes, campos de dinero, modales, carrito, arqueo en vivo, descarga del PDF, ticket, vista de celular y vista del vendedor.

Ambas toman la URL del nombre de la carpeta (o `APEX_URL` / primer argumento), crean un administrador temporal `zzadmin` y datos con prefijo `ZZ`, y lo eliminan todo al final. Si hay una caja abierta real, no la cierran. Rutas y credenciales configurables: `MYSQL_BIN`, `PHP_BIN`, `MYSQL_USER`, `MYSQL_PASS`, `APEX_DB_NAME`, `APEX_BROWSER` (`chromium` en Linux). En GitHub, cada *push* ejecuta `.github/workflows/ci.yml`.

© APEX by Ing. Antony Pérez

14. Mantenimiento y extensión

Agregar un módulo

1. Crear `modulo.php`: `require 'config/conexion.php'`, control de rol, handlers POST con `csrf_verify()` y `flash_redirect()`, luego `include 'includes/header.php'`, HTML con `h()` y `footer.php`.
2. Agregar el título en `$pageTitles` y el enlace con `nav_link()` en `includes/header.php` (dentro del bloque admin si corresponde).
3. Cambios de esquema: agregarlos a `setup.php` de forma idempotente.
4. Agregar pruebas en `tests/e2e.sh` y, si hay interfaz, en `tests/ui_test.py`.

Regenerar los manuales

```
bash docs/fuente/preparar_demo.sh          (copia de demostración + base apex_demo)
python docs/fuente/capturas.py             (capturas en docs/fuente/img)
python docs/fuente/generar_pdf.py          (PDF en docs/)
rm -rf /c/xampp/htdocs/apex_demo_manual    (limpieza)
mysql -u root -e "DROP DATABASE apex_demo"
```

Los textos están en `docs/fuente/*.html` y los estilos en `manual.css`. La demo nunca usa la base real.

Convenciones

- Textos, comentarios e identificadores de negocio en español.
- La marca siempre desde `APP_NAME` / `APP_AUTHOR` / `app_copyright()`.
- Dinero en `DECIMAL(12,2)`; en PHP redondear a 2 decimales antes de comparar.

© APEX by Ing. Antony Pérez